

Analisis de Threat Model

Presentacion Clase 3 - Desarrollo Seguro de Software

Amenazas STRIDE y OWASP LLM faltantes

Generado a partir del OCR de Presentacion_Clase_3.pdf (56 paginas)

Resumen:

La presentacion cubre las 6 categorias STRIDE y los 10 items de OWASP LLM Top 10 en teoria, pero el threat model aplicado al caso del agente de reportes (pag. 42) tiene vacios importantes en el mapeo de amenazas a controles.

1. Lo que SI cubre

STRIDE (6/6)

- S - Spoofing: tokens JWT, rotacion, binding a device
- T - Tampering: customer_id del token, no del body
- R - Repudiation: log immutable con request hash
- I - Information Disclosure: autorizacion en capa de dominio
- D - Denial of Service: rate limit + tope de costo
- E - Elevation of Privilege: allowlist de tools por rol

OWASP LLM Top 10 (10/10 listados)

- LLM01 Prompt Injection, LLM02 Sensitive Information Disclosure
- LLM03 Supply Chain, LLM04 Data & Model Poisoning
- LLM05 Improper Output Handling
- LLM06 Excessive Agency, LLM07 System Prompt Leakage
- LLM08 Vector & Embedding Weaknesses, LLM09 Misinformation
- LLM10 Unbounded Consumption

OWASP Agentic AI (parcial)

- Memory poisoning, Tool misuse, Goal manipulation
- Multi-agent collusion, Supply chain, Identity & access

MCP especifico

- Tool abuse, Confused deputy, Exfiltracion por contexto, Rug pull

2. STRIDE - Amenazas especificas no cubiertas

S - Spoofing del servidor MCP

No se menciona autenticacion mutua (mTLS) ni verificacion de identidad del servidor MCP. Un atacante podria interponer un servidor MCP malicioso via DNS spoofing, MitM o compromise del registry, y el agente se conectaria sin validar la identidad del destinatario.

Control sugerido: mTLS entre el gateway MCP y los servidores, pinning de certificados o verificacion de hash del servidor.

T - Tampering de almacenamiento persistente

Se cubre memory poisoning via prompt, pero no el tampering directo sobre la base de datos de memoria/historial. Si un atacante accede al storage de conversaciones (Postgres, Redis), puede modificar el historial que el agente leera en el futuro.

Control sugerido: firmas digitales o hashes encadenados del historial, deteccion de manipulacion offline.

D - Context window flooding (DoS especifico de LLMs)

No se cubre el ataque donde un atacante llena deliberadamente la ventana de contexto con datos irrelevantes o repetitivos para forzar al modelo a ignorar instrucciones del system prompt (attention dilution) o para disparar costos de inferencia desmedidos.

Control sugerido: maximo de tokens por sesion, summarization obligatorio, monitoreo de relacion prompt/contexto util.

E - Privilege escalation por tool chaining

El analisis trata cada tool de forma aislada, pero no evalua combinaciones. Un agente con tools de lectura de archivo + envio de email podria exfiltrar datos sin tener una tool de exfiltracion explicita. La composicion de permisos no se analiza.

Control sugerido: analisis de grafos de permisos, capability flags por sesion, deteccion de secuencias anomalas de tool calls.

3. OWASP LLM - Amenazas con cobertura parcial o ausente

LLM03 - Supply Chain (ausente en el threat model)

Aunque se menciona en la teoria (pag. 26: "Modelos, fine-tunes, embeddings, datasets, adapters: cada uno es una dependencia"), NO aparece en la tabla de threat model (pag. 42). No hay ningun componente mapeado para riesgos de supply chain.

Amenazas no cubiertas:

- Adaptador LoRA envenenado en produccion (pag. 26 lo menciona como concepto, pero no hay control)
- Provenance del modelo base: que garantias hay de que el modelo no fue manipulado antes del deploy?
- Dependencias de librerias de embedding/vector store con vulnerabilidades conocidas
- Actualizaciones automaticas del modelo que cambian comportamiento sin revision

Control sugerido: SBOM del pipeline de IA, hash verification de modelos y adaptadores, staging environment para validar nuevos modelos.

LLM09 - Misinformation (sin control en la tabla)

Se menciona en teoria (pag. 27: "El modelo afirma cosas falsas con confianza") pero no tiene fila propia en el threat model. En un sistema de reportes financieros, una alucinacion sobre el saldo de una cuenta es un riesgo grave.

Amenazas no cubiertas:

- Reportes financieros inventados que el usuario ejecuta como ciertos
- Confianza ciega del siguiente sistema en la salida del LLM (pag. 27 lo menciona pero no hay control)
- Contaminacion cruzada: el modelo mezcla datos de distintos clientes y genera una verdad plausible pero incorrecta

Control sugerido: citation grounding (cada afirmacion debe referenciar un dato real), verificacion contra la BD antes de responder, confidence thresholds.

LLM08 - Vector & Embedding Weaknesses (cobertura superficial)

La tabla solo menciona provenance + allowlist de fuentes. Faltan:

- Adversarial queries contra embeddings para recuperar documentos de otros tenants
- Cross-tenant leakage en vector stores compartidos
- Data remanence: los vectores se eliminan realmente cuando se borra un cliente?

Control sugerido: vector store multi-tenant con aislamiento fisico o logical, sanitizacion de documentos antes de embed, rotation de embeddings.

4. OWASP Agentic AI - Amenazas no cubiertas

Goal manipulation persistente

Se menciona en la lista de la pagina 28 pero no tiene control especifico en el threat model. Como se detecta que un atacante re-escribio el objetivo del agente a traves de una conversacion larga?

Control sugerido: goal integrity check periodico, system prompt re-assertion por turnos, deteccion de desviacion semantica.

Model theft / Model extraction

No se cubre la extraccion del modelo a traves de queries repetitivas (model stealing via API). Un atacante podria reconstruir un modelo sustituto consultando la API del agente y recolectando pares prompt-respuesta.

Control sugerido: rate limiting por patron de consulta, deteccion de queries de sondeo, watermarking de respuestas.

Insecure agent-to-agent communication

Si el sistema evoluciona a multiples agentes, no hay cobertura de comunicacion entre ellos. Un agente comprometido podria contaminar a otros.

Control sugerido: aislamiento de contextos, autenticacion entre agentes, politicas de comunicacion explicitas.

5. Tabla resumen: amenaza -> control faltante

Amenaza	Categoria	Control faltante sugerido
Spoofing MCP server	STRIDE - S	mTLS, cert pinning, verificacion de identidad del servidor
Tampering de historial	STRIDE - T	Firmas digitales del historial, hashes encadenados
Context window flooding	STRIDE - D / LLM10	Maximo de tokens por sesion, monitoreo de atencion
Tool chaining	STRIDE - E / LLM06	Analisis de grafos de permisos, capability flags
Supply Chain (LLM03)	OWASP LLM	SBOM, hash verification, staging para modelos nuevos
Misinformation (LLM09)	OWASP LLM	Citation grounding, verificacion contra BD, confidence thresholds
Adversarial embeddings	OWASP LLM (LLM08)	Vector store multi-tenant, sanitizacion de documentos
Goal manipulation	OWASP Agentic	Goal integrity check, system prompt re-assertion
Model extraction	OWASP Agentic	Rate limiting por patron, watermarking, deteccion de sondeo